Using clear terminology allows teams to discuss authorization consistently and precisely, which becomes even more crucial as systems grow in complexity. With our language established, we can examine how these concepts come together in a typical authorization architecture. Let's consider who makes the decisions, where they are enforced, and how everything interconnects.

4.4 Authorization reference architecture

To truly grasp how modern authorization systems are constructed, it’s beneficial to look back at one of the earliest and most comprehensive efforts to shape their architecture: XACML, which stands for the eXtensible Access Control Markup Language.

Back in the early 2000s, OASIS introduced XACML, and it was more than just a policy language—it established a comprehensive model for making and enforcing access control decisions! It really helped clarify the separation of concerns that many of our modern systems still adhere to today. Specifically, XACML provided us with a clear architecture that revolves around these four key components:

- **Policy Enforcement Point (PEP)**—where access is intercepted and checked
- **Policy Decision Point (PDP)**—where policies are evaluated to reach a decision
- **Policy Administration Point (PAP)**—where policies are created and managed
- **Policy Information Point (PIP)**—a source of contextual data and attributes

Although XACML—which uses verbose XML and can be quite complex to implement—hasn’t become widely adopted in modern systems, its architectural model has made a significant impact and has become a reference architecture for authorization systems.